

- JavaScript source code analysis
- File inclusion
- Backup files check

5. SQLMap

With a specific focus on SQL injection vulnerabilities, SQLMap is a great open source tool that automates the process of detecting and exploiting SQL injection flaws and taking over database servers. It comes with an interactive and relatively easy to use CLI, and is written in Python. Its latest version (Shazora Bradleflame) was released in January 2021 and it has an active developer community. The major highlights of SQLMap are:

- Full support for all major databases, including MySQL, PostgreSQL, IBM DB2 and SQLite
- Support for all 6 SQL injection techniques
- Enumeration of user password hashes
- Automatic recognition of password hashes
- Download and upload file support
- Database process' user privilege escalation
- Detailed documentation available in multiple languages

4. Arachni

Designed for penetration testing and systems administration, Arachni is a full-featured high performance Ruby framework. It is multi-platform, versatile and has a REST based API. The only drawback is that the app has not received any updates since 2017 when its last version (v1.5.1) was released. With no new updates and lack of community support, the tool is not ideal for those not familiar with Ruby and/or are beginners in penetration testing. The major

highlights of Arachni are:

- SSL support with fine-grained options
- Custom header support
- UI abstraction
- Automatic logout detection and scanning upon re-login
- High performance asynchronous HTTP requests
- Proxy authentication
- Cookie-jar / cookie-string support

3. Wireshark

Started in 1998 by Gerald Combs, Wireshark is a comprehensive network protocol analyser that helps you go into the nitty gritty details of each visit to your website and each active connection. If you require a microscopic look into your system's network traffic, Wireshark is the tool to opt for. It has an active and vibrant developer community with excellent support tools. The major highlights of Wireshark are:

- In-depth analysis of hundreds of protocols
- Live and offline analysis
- Multi-platform support
- VoIP analysis
- Decryption support for a wide range of protocols
- Data can be exported to CSV, XML and other formats
- Coloured rule highlighting for intuitive analysis

2. Nogotofail

Released in 2014 as an open source project by Google, Nogotofail is a lightweight application

that can be used to spot and fix vulnerable TLS/ SSL connections. It was designed keeping in mind developers and security researchers. The one drawback is that the last version (v1.2.0) for this application was released in 2015. With no regular updates and shoddy community support, the application may not be ideal for absolute beginners. The major highlights of Nogotofail are:

- SSL certificate verification
- VPN/proxy support
- Lightweight and easy to deploy
- MiTM attack detection support
- SSL injection vulnerability test
- TLS injection vulnerability test
- Sensitive cleartext traffic detection support

1. OSSEC

OSSEC is the only framework in this list with machine learning support, which instantly makes it more attractive than others. It is an open source host-based intrusion detection system. It has multi-platform support and has different versions that fit different enterprise needs. With its latest version (v3.6.0) out in February 2020, OSSEC is a well maintained application with active community support and detailed documentation. The major highlights of OSSEC are:

- Log analysis
- File integrity analysis
- Policy monitoring
- Rootkit detection
- Real-time alerts
- Active response
- Machine learning support 

By: Mir H.S. Quadri

The author is a research analyst with a specialisation in artificial intelligence and machine learning. He is the founder of *codelatte.site* and the executive editor of *intrigue.blog*. He shares a deep love for the analysis of technological trends and understanding their implications. Being a FOSS enthusiast, he has contributed to several open source projects.